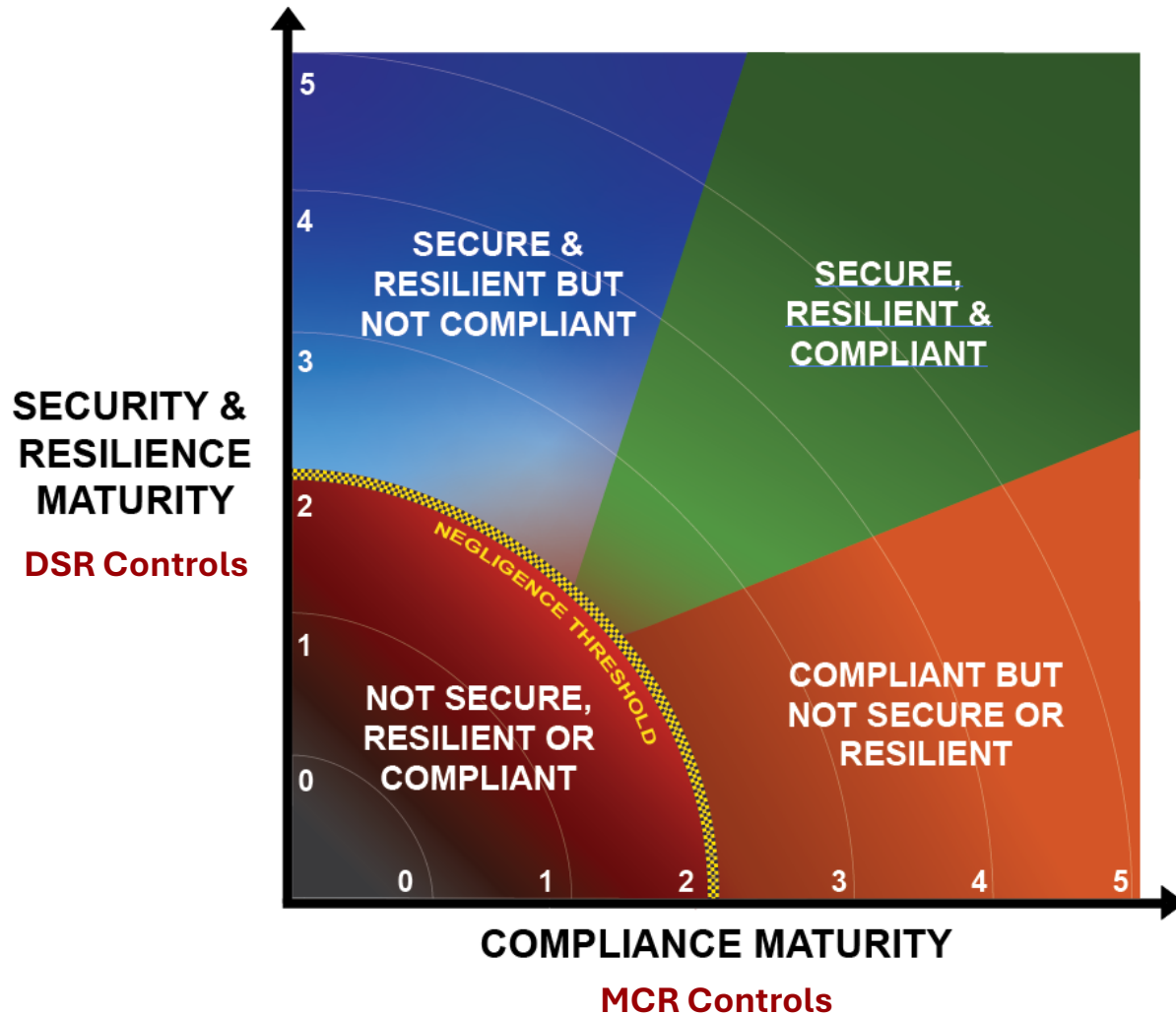




The Heartbeat of Compliance™

<https://securecontrolsframework.com>

Defining The Problem



Choose where you want to be:

1. Not secure, resilient, or compliant.
2. Compliant, but not fully secure or resilient.
3. Secure & resilient, but not compliant.
4. Secure, resilient & compliant.

The SCF Empowers Risk Discussions

The structure of the SCF normalizes disparate control language into something that is usable across technology, cybersecurity, privacy and other departments where they can share the same control language. **The SCF enables informed risk discussions.**

[illegible]

Comprehensive Coverage: 33 Domains With Principles

Security, Compliance & Resilience (SCR) Principles

The Secure Controls Framework (SCF) established 33 common-sense principles to guide the development and oversight of a modern cybersecurity & data privacy program. The focus is for organizations to be secure, compliant and resilient. The SCF's comprehensive listing of over 1,400 cybersecurity & data protection controls is categorized into 33 domains and are mapped to over 200 authoritative sources (e.g., laws, regulations and frameworks). Those applicable SCF controls can operationalize the SCR principles to help an organization ensure that secure, compliant and resilient practices are implemented by design and by default. Those principles are listed below:

**1. Cybersecurity & Data Protection Governance (GOV)**

Execute a documented, risk-based program that supports business objectives while encompassing appropriate cybersecurity & data protection principles that addresses applicable statutory, regulatory and contractual obligations.

**2. Artificial Intelligence and Autonomous Technology (AAT)**

Ensure trustworthy and resilient Artificial Intelligence (AI) and autonomous technologies to achieve a beneficial impact by informing, advising or simplifying tasks, while minimizing emergent properties or unintended consequences.

**3. Asset Management (AST)**

Manage all technology assets from purchase through disposition, both physical and virtual, to ensure secured use, regardless of the asset's location.

**4. Business Continuity & Disaster Recovery (BCD)**

Maintain a resilient capability to sustain business-critical functions while successfully responding to and recovering from incidents through well-documented and exercised processes.

**5. Capacity & Performance Planning (CAP)**

Govern the current and future capacities and performance of technology assets.

**6. Change Management (CHG)**

Manage change in a sustainable and ongoing manner that involves active participation from both technology and business stakeholders to ensure that only authorized changes occur.

**7. Cloud Security (CLD)**

Govern cloud instances as an extension of on-premise technologies with equal or greater security protections than the organization's own internal cybersecurity & data privacy controls.

**8. Compliance (CPL)**

Oversee the execution of cybersecurity & data privacy controls to ensure appropriate evidence required due care and due diligence exists to meet compliance with applicable statutory, regulatory and contractual obligations.

**9. Configuration Management (CFG)**

Enforce secure configurations according to vendor-recommended and industry-recognized secure practices that enforce the concepts of "least privilege" and "least functionality" for all systems, applications and services.

**10. Continuous Monitoring (MON)**

Maintain situational awareness of security-related events through the centralized collection and analysis of event logs from systems, applications and services.

**11. Cryptographic Protections (CRY)**

Utilize appropriate cryptographic solutions and industry-recognized key management practices to protect the confidentiality and integrity of sensitive/regulated data both at rest and in transit.

**12. Data Classification & Handling (DCH)**

Enforce a standardized data classification methodology to objectively determine the sensitivity and criticality of all data and technology assets so that proper handling and disposal requirements can be followed.

**13. Embedded Technology (EMB)**

Provide additional scrutiny to reduce the risks associated with embedded technology, based on the potential damages posed from malicious use of the technology.

**14. Endpoint Security (END)**

Harden endpoint devices to protect against reasonable threats to those devices and the data those devices store, transmit and process.

**15. Human Resources Security (HRS)**

Execute sound hiring practices and ongoing personnel management to cultivate a cybersecurity & data privacy-minded workforce.

**16. Identification & Authentication (IAC)**

Enforce the concept of "least privilege" consistently across all systems, applications and services for individual, group and service accounts through a documented and standardized Identity and Access Management (IAM) capability.

**17. Incident Response (IRO)**

Maintain a viable incident response capability that trains personnel on how to recognize and report suspicious activities so that trained incident responders can take the appropriate steps to handle incidents, in accordance with a documented Incident Response Plan (IRP).

**18. Information Assurance (IAC)**

Execute an impartial assessment process to validate the existence and functionality of appropriate cybersecurity & data privacy controls, prior to a system, application or service being used in a production environment.

**19. Maintenance (MNT)**

Proactively maintain technology assets, according to current vendor recommendations for configurations and updates, including those supported or hosted by third-parties.

**20. Mobile Device Management (MDM)**

Implement measures to restrict mobile device connectivity with critical infrastructure and sensitive/regulated data that limit the attack surface and potential data exposure from mobile device usage.

**21. Network Security (NET)**

Architect and implement a secure and resilient defense-in-depth methodology that enforces the concept of "least functionality" through restricting network access to systems, applications and services.

**22. Physical & Environmental Security (PES)**

Protect physical environments through layers of physical security and environmental controls that work together to protect both physical and digital assets from theft and damage.

**23. Data Privacy (PRI)**

Align data privacy practices with industry-recognized data privacy principles to implement appropriate administrative, technical and physical controls to protect regulated personal data throughout the lifecycle of systems, applications and services.

**24. Project & Resource Management (PRM)**

Operationalize a viable strategy to achieve cybersecurity & data privacy objectives that establishes cybersecurity as a key stakeholder within project management practices to ensure the delivery of resilient and secure solutions.



**25. Risk Management (RSK)**

Proactively identify, assess, prioritize and remediate risk through alignment with industry-recognized risk management principles to ensure risk decisions adhere to the organization's risk threshold.

**26. Secure Engineering & Architecture (SEA)**

Utilize industry-recognized secure engineering and architecture principles to deliver secure and resilient systems, applications and services.

**27. Security Operations (OPS)**

Execute the delivery of cybersecurity & data privacy operations to provide quality services and secure systems, applications and services that meet the organization's business needs.

**28. Security Awareness & Training (SAT)**

Foster a cybersecurity & data privacy-minded workforce through ongoing user education about evolving threats, compliance obligations and secure workplace practices.

**29. Technology Development & Acquisition (TDA)**

Develop and/or acquire systems, applications and services according to a Secure Software Development Framework (SSDF) to reduce the potential impact of undetected or unaddressed vulnerabilities and design flaws.

**30. Third-Party Management (TPM)**

Execute Supply Chain Risk Management (SCRM) practices so that only trustworthy third-parties are used for products and/or service delivery.

**31. Threat Management (THR)**

Proactively identify and assess technology-related threats, to both assets and business processes, to determine the applicable risk and necessary corrective action.

**32. Vulnerability & Patch Management (VPM)**

Leverage industry-recognized Attack Surface Management (ASM) practices to strengthen the security and resilience systems, applications and services against evolving and sophisticated attack vectors.

**33. Web Security (WEB)**

Ensure the security and resilience of Internet-facing technologies through secure configuration management practices and monitoring for anomalous activity.

Copyright © 2026 by Secure Controls Framework Council, LLC (SCF Council). All rights reserved.

All text, images, logos, trademarks and information contained in this document are the intellectual property of SCF Council, unless otherwise indicated. Modification of any content, including text and images, requires the prior written permission of SCF Council. Requests may be sent to support@securecontrolsframework.com.

<https://securecontrolsframework.com/start-here/scf-domains-principles/>



SECURE
CONTROLS
FRAMEWORK

The Common Controls Framework (CCF)

The SCF is not just another framework. It is a metaframework – a framework of frameworks.

- Covers over 200 cybersecurity laws, regulations and frameworks with over 1,400 controls.
- The SCF is a free resource
- Contains defined:
 - Maturity model criteria
 - Evidence Request List (ERL)
 - Assessment Objectives (AOs)
 - Risk & threat catalogs



A Rosetta Stone Approach To Cybersecurity Frameworks

The SCF normalizes disparate requirements found in laws, regulations and frameworks.

These controls establish how organizations manage risks through preventing, detecting or lessening the ability of a particular threat from negatively impacting business processes.

con • trol
/kən trol/

In practical terms, a control is the power to influence or direct behaviors and the course of events. **Controls are technical, administrative or physical safeguards.**

What Is The SCF Is

The SCF is:

- A control set that is based on 33 core cybersecurity & data privacy principles. These 33 domains provide the structure to the SCF.
- A metaframework that provides a “Rosetta Stone” approach to organizing cybersecurity and privacy controls so that the same controls can be used among companies and teams (e.g., data privacy, cybersecurity, IT, PM, procurement, etc.).
- Free for businesses to use. A result of a volunteer-led effort that uses “expert derived assessments” to perform the mapping from the controls to applicable laws, regulations and other frameworks.

What Is The SCF Is NOT

The SCF is not:

- A substitute for performing due diligence and due care steps to understand your specific compliance needs.
- A complete technology or documentation solution to address all your cybersecurity & data privacy needs (e.g., the policies, standards, procedures and processes you need to have in place to be secure and compliant).
- Infallible or guaranteed to meet every compliance requirement your organization offers, since the controls are mapped based on expert-derived assessments to provide the control crosswalking that relies on human expertise and that is not infallible.

The SCF Continues To Innovate & Evolve

The SCF is free for businesses to use per the Creative Commons licensing model. The SCF can be downloaded as an Excel spreadsheet from the SCF website or GitHub.

The current version of the SCF contains:

- **33 domains**
- **1,400+ Controls**
- **Control weighting**
- **Control questions**
- **Maturity Model Criteria**
- **Risk catalog**
- **Threat catalog**
- **Crosswalk mapping to over 250 laws, regulations and frameworks**
- **Compensating Controls**
- **Evidence Request List (ERL)**
- **Assessment Objectives (AOs)**
- **PPTDF-AI Tagging**
- **Data Privacy Management Principles**

NIST-Based Mapping = Transparency & Increased Trust

The SCF leverages NIST IR 8477's concepts for **Set Theory Relationship Mapping (STRM)** to conduct crosswalk mapping. NIST IR 8477 is the “gold standard” for how to perform this type of mapping.



Integrated Controls Management (ICM) Mindset

Cybersecurity is controls-centric, where controls are viewed as the nexus, or central pivoting point, for an organization's cybersecurity and data protection operations.

This affects the entity's overall business rhythm, since the controls used to define "secure practices" have both direct and indirect impacts on the Technology Assets, Applications, Services and/or Data (TAASD) that business operations rely upon.



Finding The “Controls Goldilocks” (Just The Right Fit)



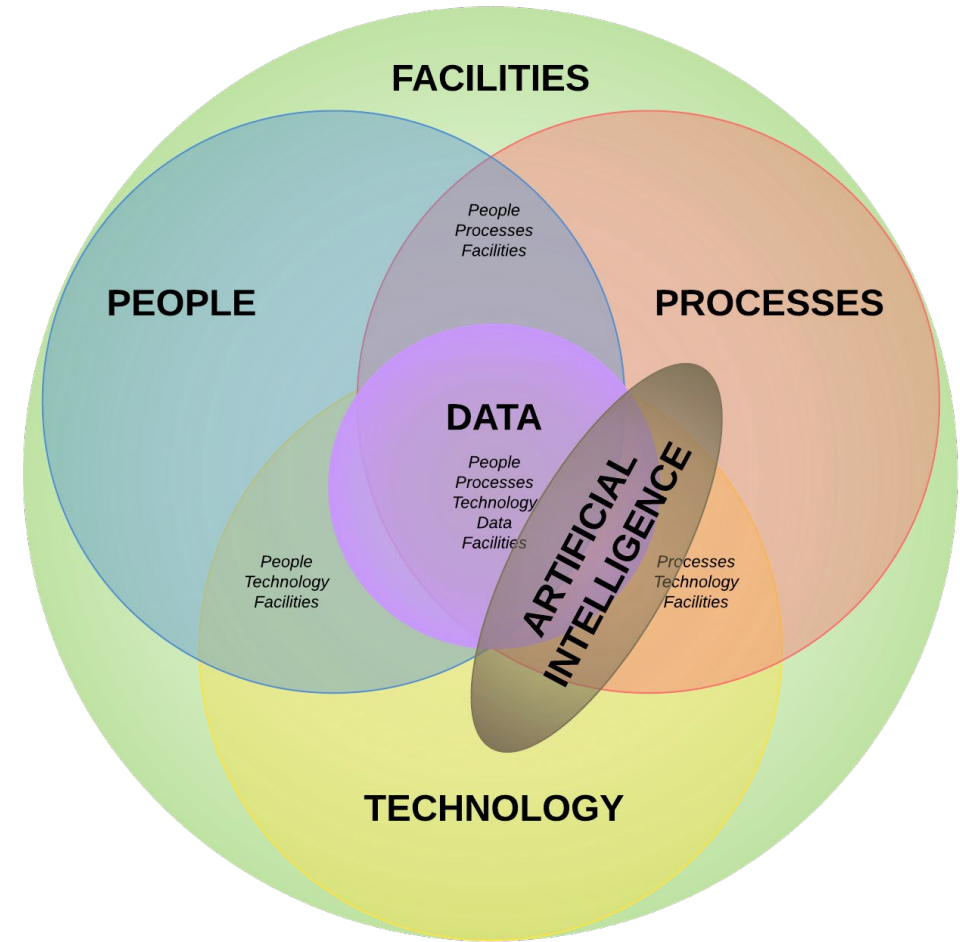
If you've spent any time reading through cybersecurity and privacy frameworks, you will quickly see that they are not equal in many ways:

- **Scope of coverage (breath)**
- **Amount of details provided (depth)**
- **Taxonomy (overall arrangement of requirements & formatting)**
- **Industry-specific terminology**

Control Applicability Using The PPTDF-AI Model

PPTDF-AI is a lens to conceptualize the applicability of controls:

- People. Humans (e.g., training, background checks, non-disclosure agreements, etc.).
- Processes. Administrative work performed (e.g., processes, procedures, administrative documentation, etc.).
- Technologies. Systems, applications and services (e.g., secure baseline configurations, patching, etc.).
- Data. Data protection (e.g., encrypting sensitive and/or regulated data, applying metatags, etc.).
- Facilities. Infrastructure assets (e.g., physical access, HVAC systems, visitor control, etc.).
- AI. Artificial Intelligence (AI) and autonomous technologies.



The Reality: A Protracted War On An Asymmetric Battlefield

Security + Compliance + Resilience needs to be a unified objective with a multi-discipline approach to cybersecurity and data protection. This approach signals that an organization isn't just secure, but also meets its compliance requirements and can quickly bounce back from incidents.

The SCF has 3 key goals:

- 1. Minimize an entity's attack surface.**
- 2. Provide the roadmap to be secure, compliant and resilient.**
- 3. Promote “defensible evidence” of reasonable practices.**

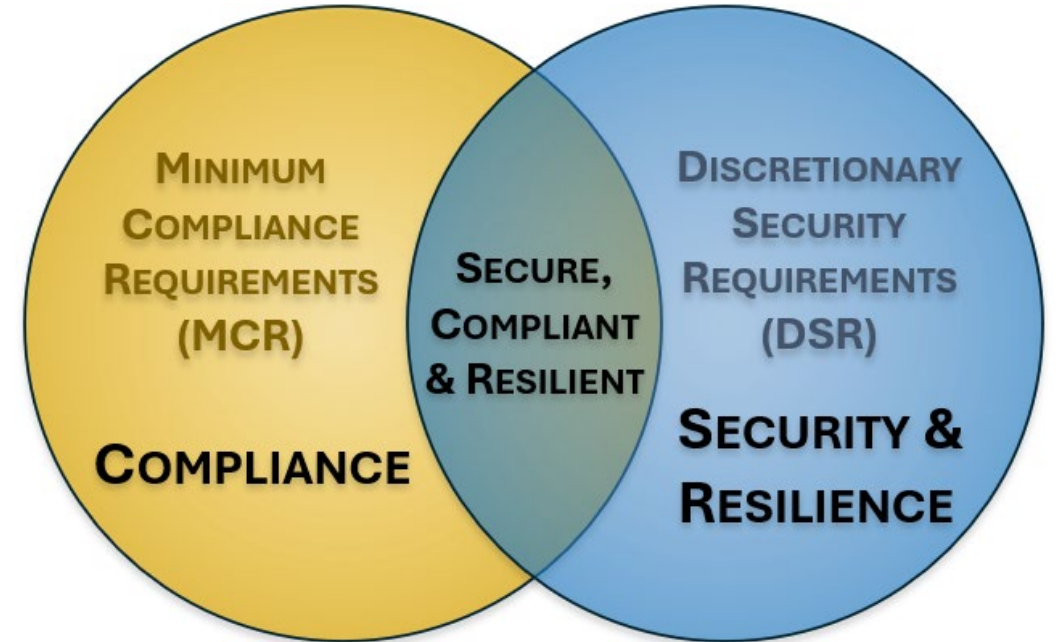


SECURE
CONTROLS
FRAMEWORK

Appropriate Controls Helps Minimize The Attack Surface

Minimizing an organization's attack surface must address more than just technical threats. This process involves defining a **Living Control Set (LCS)** that defines **Minimum Security Requirements (MSR)** necessary to be secure, compliant and resilient:

- **Minimum Compliance Requirements (MCR)** are the absolute minimum requirements that must be addressed to comply with applicable laws, regulations and contracts. MCR focuses on compliance.
- **Discretionary Security Requirements (DSR)** are based on the organization's respective industry expectations and risk tolerance. DSR focuses on security and resilience.



Defensible Evidence Focuses On What You Can Prove

Defensible evidence is the verifiable and objective proof that your organization's security, compliance, and resilience activities:

- Actually occurred
- Were effective
- Can withstand external scrutiny

Defensible evidence can be viewed as on-demand assurance for stakeholders, where assurance is:

- Evidence-based confidence
- The demonstrable output of security, compliance and resilience activities



Security + Compliance + Resilience = Unified Objective

Security = Prevent

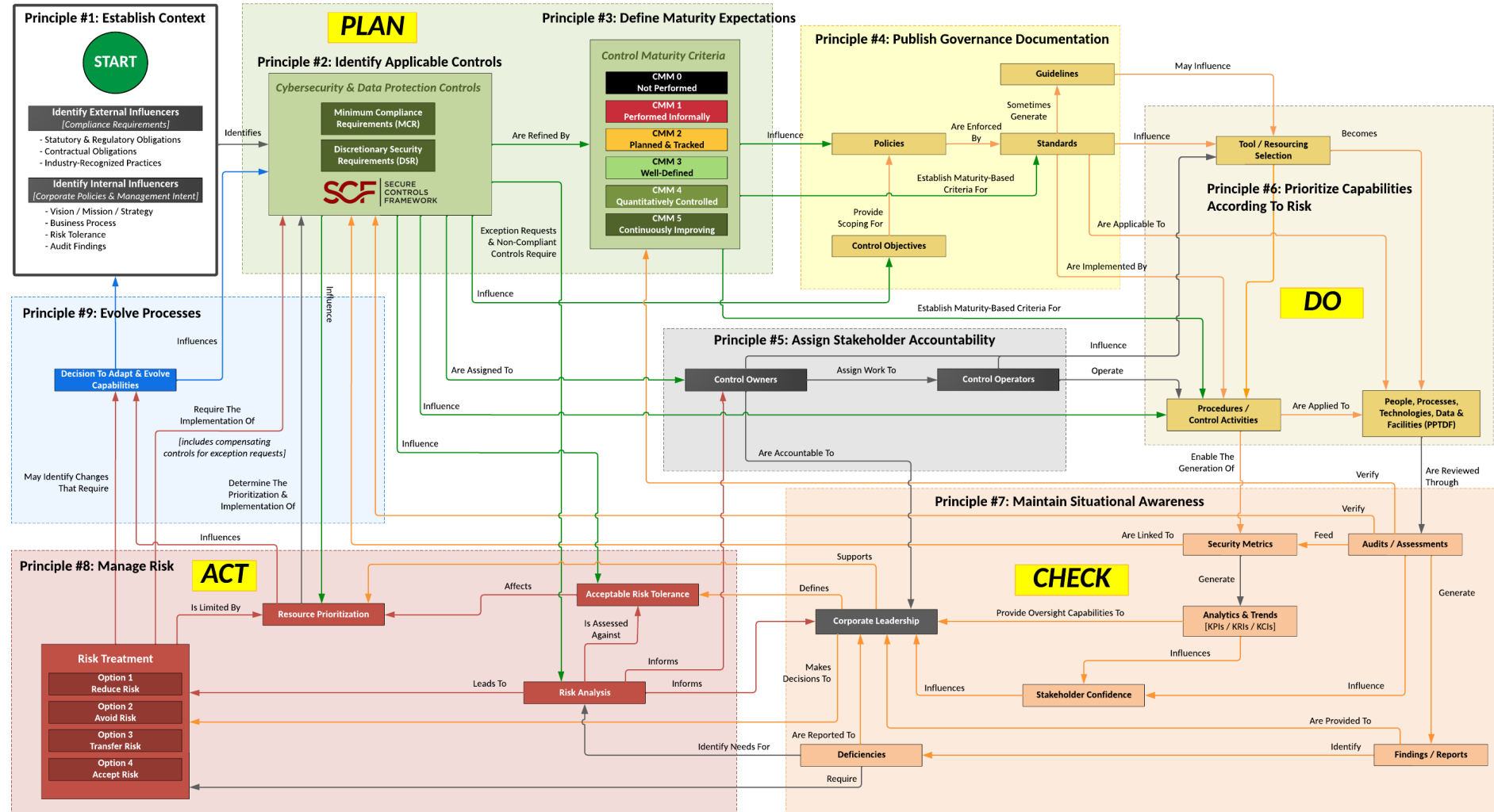
Compliance = Prove

Resilience = Survive



SECURITY,
COMPLIANCE &
RESILIENCE
MANAGEMENT
SYSTEM

Plan, Do, Check & Act (PDCA) Approach To Capabilities



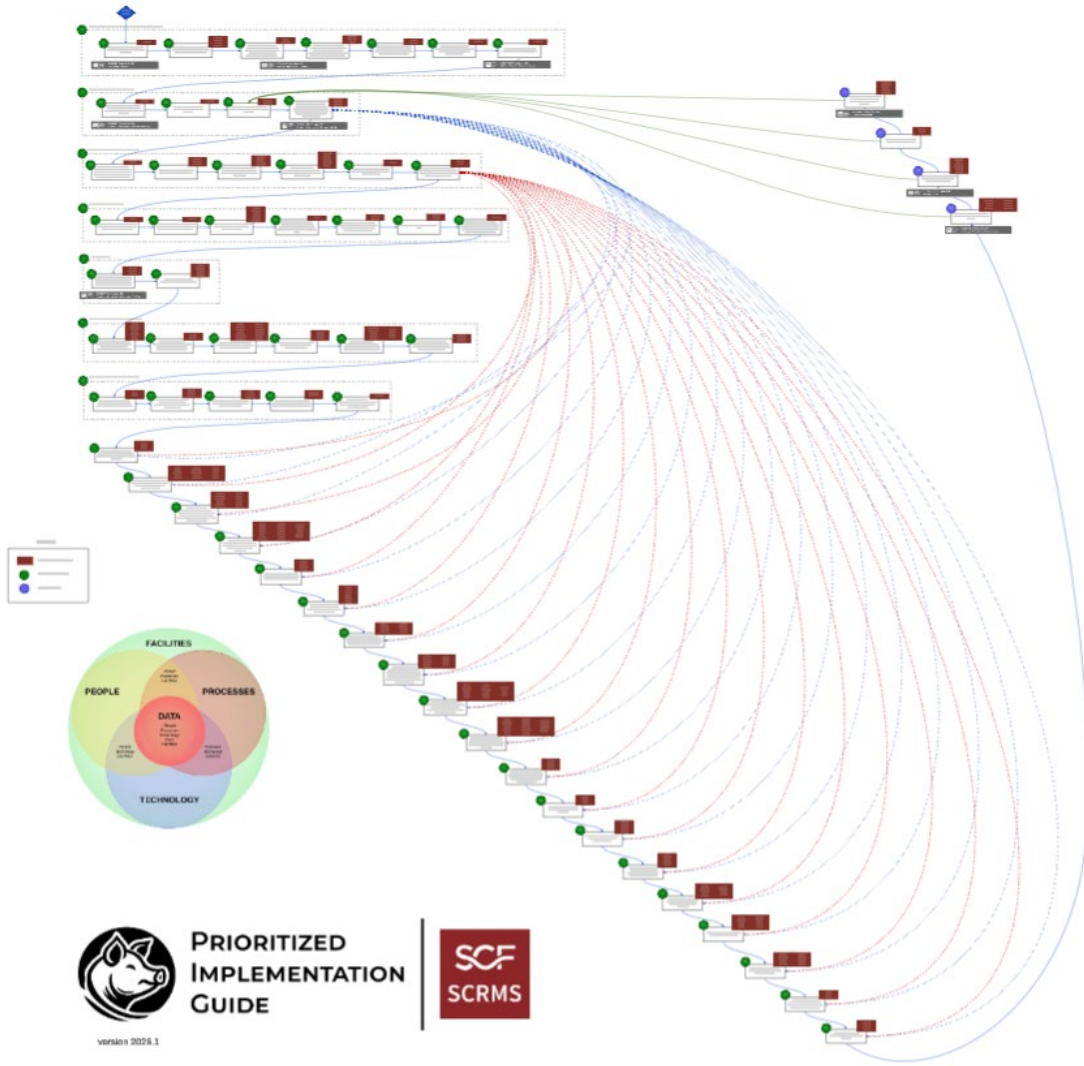
PDCA Principles: Focus On Being Secure, Compliant & Resilient

From a “How To GRC” perspective, there are defined steps that can be implemented to operationalize PDCA principles with the SCF:

1. **Establish Context**
2. **Identify Applicable Controls**
3. **Define Maturity Expectations**
4. **Publish Governance Documentation**
5. **Assign Stakeholder Accountability**
6. **Prioritize Capabilities According To Risk**
7. **Maintain Situational Awareness**
8. **Manage Risk**
9. **Evolve Processes**



SCRMS Prioritized Implementation Plan (SCRMS-PIG)



The SCRMS comes with a practitioner-focused guidebook to implement a prioritized rollout of capabilities.

This guide breaks the SCRMS down into 30 steps:

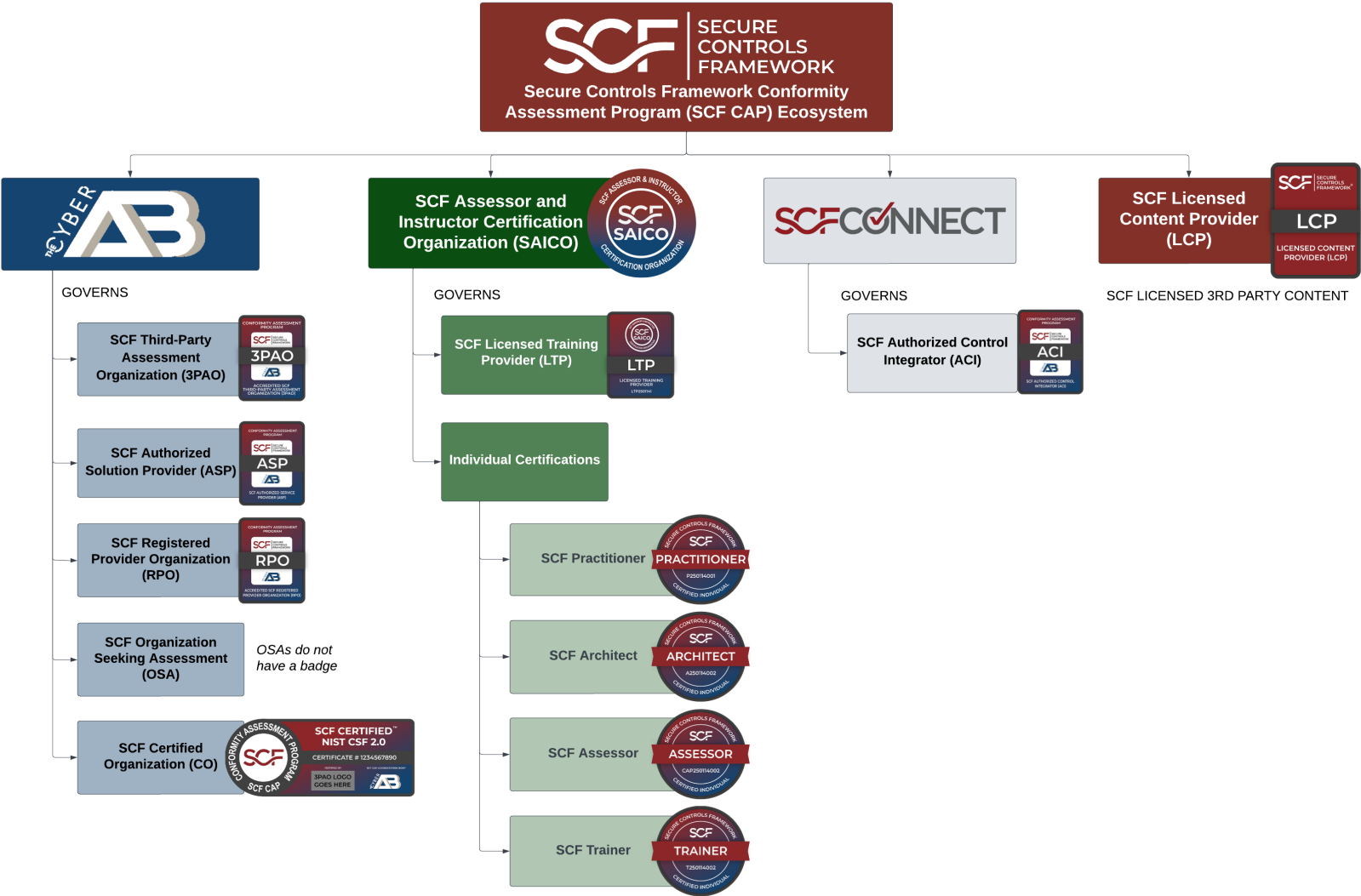
- 26 steps focused on due diligence.
- 4 steps focused on due care.

The SCRMS-PIG can be used to create a project plan for implementation purposes.

SCF Conformity Assessment Program (SCF CAP)



SCF CAP Ecosystem



SCF CAP – Multiple Framework Options



ASSESSMENT GUIDE

NIST CYBERSECURITY
FRAMEWORK (NIST CSF 2.0)



ASSESSMENT GUIDE

CMMC LEVEL 1



ASSESSMENT GUIDE

NIST SP 800-171 R3



ASSESSMENT GUIDE

CMMC L2 TO NIST CSF 2.0
RECIPROCITY



ASSESSMENT GUIDE

NY DFS
23 NYCRR PART 500



ASSESSMENT GUIDE

NIST SP 800-161 R1
C-SCRM BASELINE



ASSESSMENT GUIDE

HIPAA SECURITY RULE
(NIST SP 800-66 R2)



ASSESSMENT GUIDE

NIST SP 800-218
SSDF v1.1



ASSESSMENT GUIDE

CISA SECURE SOFTWARE
DEVELOPMENT ATTESTATION FORM



ASSESSMENT GUIDE

NZ HEALTH INFORMATION SECURITY
FRAMEWORK GUIDANCE FOR SUPPLIERS



ASSESSMENT GUIDE

SCF CORE
FUNDAMENTALS



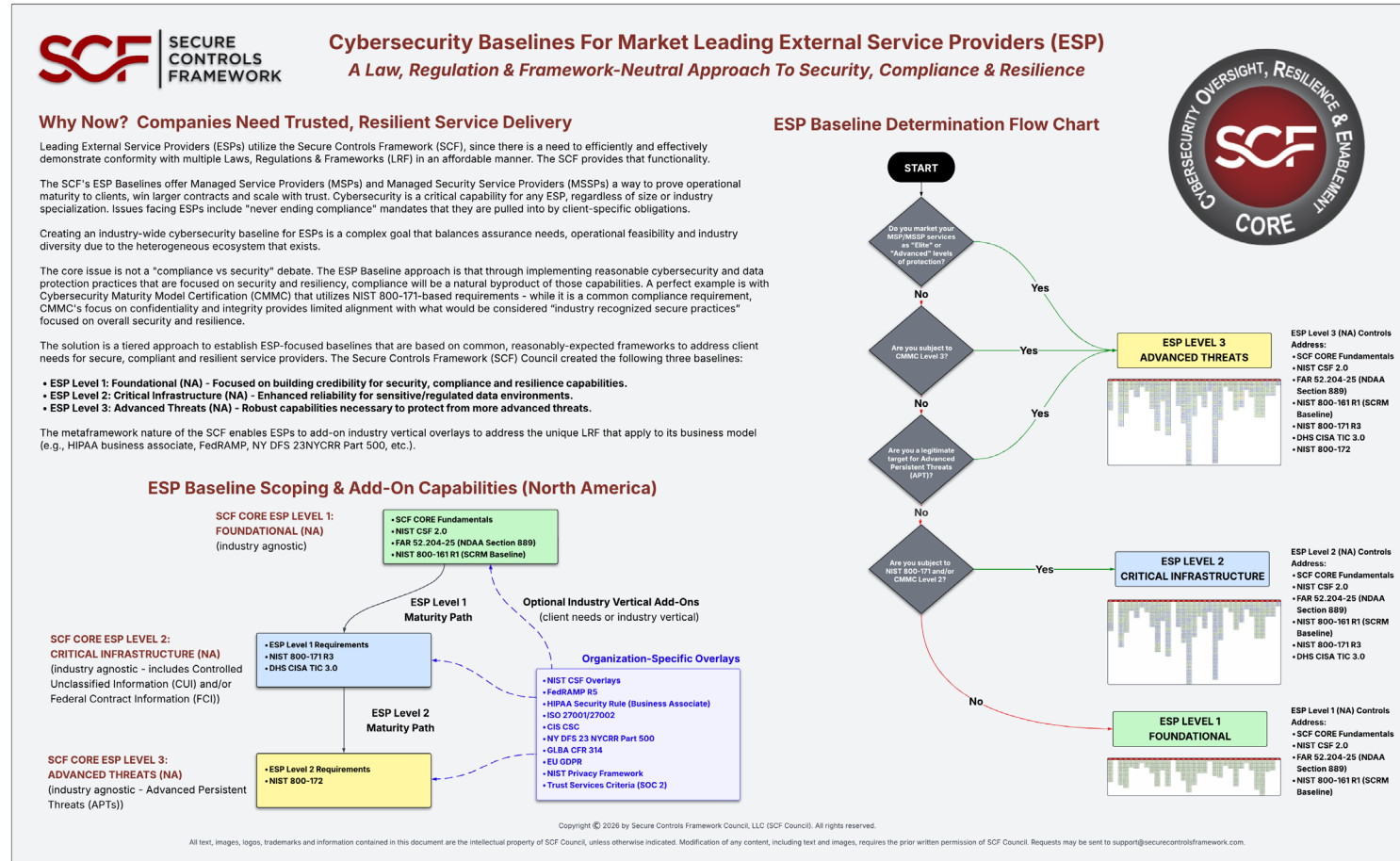
ASSESSMENT GUIDE

SCF TAILORED



SECURE
CONTROLS
FRAMEWORK

Standardization For External Service Providers (ESPs)



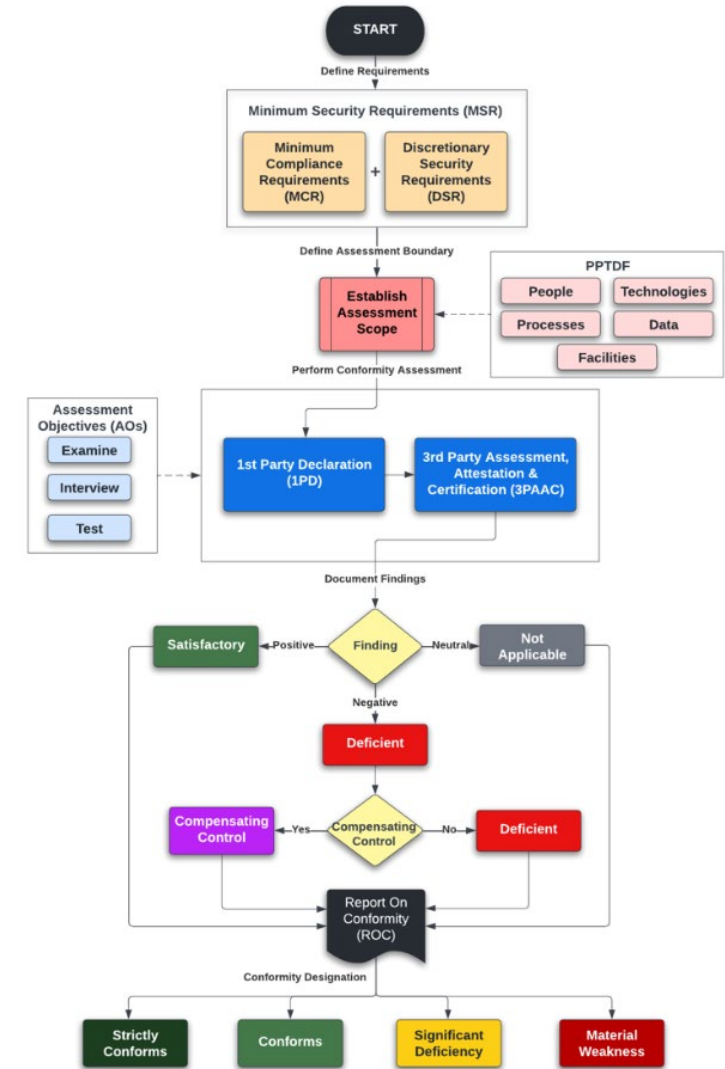
<https://securecontrolsframework.com/core/>

Demonstrating Assurance To Stakeholders

The SCF has an assurance mechanism, the Security, Compliance & Resilience Conformity Assessment Program (SCR CAP).

The SCR CAP is an organization-level conformity assessment that is designed to utilize tailored cybersecurity and privacy controls that specifically address the applicable security, compliance and resilience requirements.

By using the metaframework nature of the SCF, an entity can perform a conformity assessment that spans multiple cybersecurity and data privacy-specific laws, regulations and frameworks.

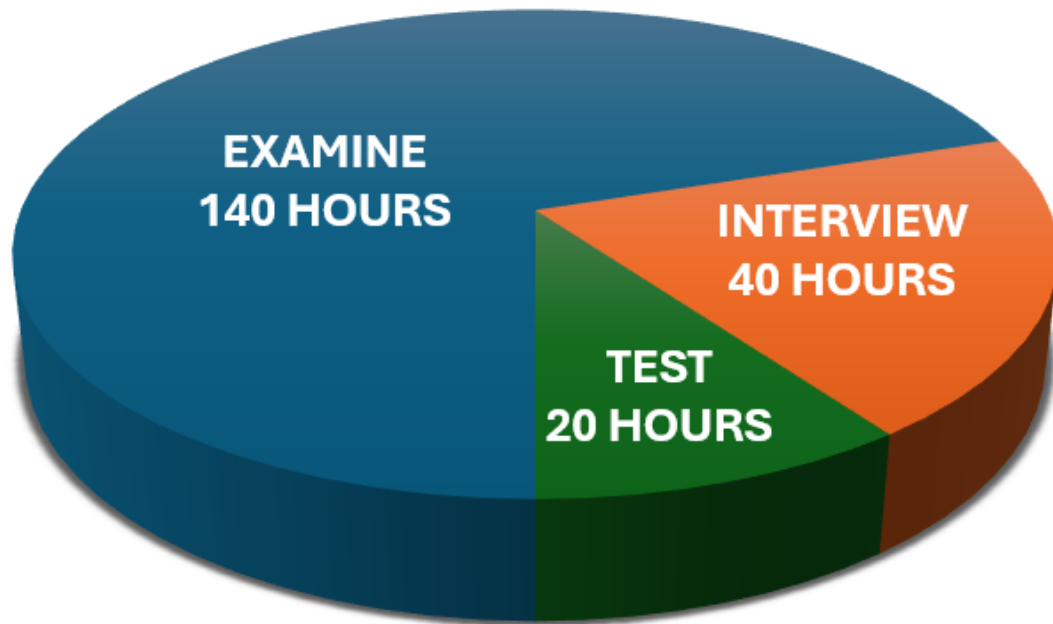


How AI Augmentation Affects A 200-Hour Assessment

The SCF CAP supports the ability to leverage AI tools for documentation review to:

- Increase efficiencies; and
- Decrease costs.

TRADITIONAL 70/20/10 BREAKDOWN



**56%
DECREASE
IN LABOR**

AI-AUGMENTED BREAKDOWN



Individual Certification Options

The SCF has three (3) individual-level certifications:



SECURE
CONTROLS
FRAMEWORK



SECURE
CONTROLS
FRAMEWORK

Questions?

support@securecontrolsframework.com